

Juan Pablo de Legarreta

NETC 180 – Information Risk Management

Module Five Assignment

Risk Management Framework Selection

RG Enterprises is facing a myriad of challenges. Confronting a multitude of risks of different types and from various sources, RG Enterprises needs a way to organize its risk management. Using a Risk Management Framework would be a great step toward mitigating the risks that it currently faces. There are many kinds of Risk Management Frameworks, designed for different purposes and types of organizations. For RG Enterprises, the most appropriate framework is the ISO 31000 Risk Management Framework.

Risk Management Framework Justification

ISO 31000 has great benefits for RG Enterprises, including its generic approach, customizability, and its risk management process, framework, and principles:

1. Generic Approach

The ISO 31000 Standard of Risk Management is a generic approach that is not specific to any industry or sector and can be applied to any type of risk and organization. (Marsden, 2) This is a big benefit to RG Enterprises, a T-shirt manufacturing business, because lots of other risk management frameworks are designed with IT companies in mind. For example, COBIT has a focus on “IT management and governance”, TARA is used to “identify and assess cybersecurity vulnerabilities and select countermeasures”, ISO/IEC 27001 “offers guidance on how to manage information security”. (Violino) COBIT, TARA, and ISO/IEC 27001 are too specific to be effective for RG Enterprises.

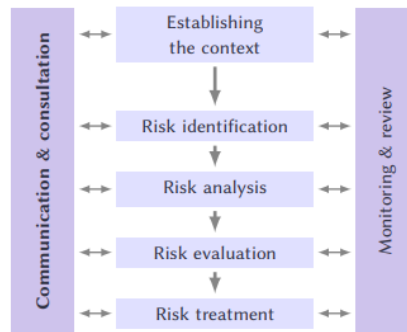
The generic approach accounts for risks of different kinds, providing RG Enterprises with a framework that is applicable throughout the organization, saving time and money in creating it and implementing it more quickly. In this way, ISO 31000 is a superior choice for RG Enterprises than other more convoluted frameworks that would take too long to figure out, establish, and implement. Two of those frameworks are COSO ERM, which has a “multidimensional nature of risk management” shown in a diagram as the faces of a cube and a six-pronged ribbon approach to risk management integration – two overly complicated components to creating a risk management framework; and FAIR, which is a quantitative analysis that requires assigning a financial value for different risks – an arduous process that would take much longer than what RG Enterprises has before facing some of the impending risks. (UpGuard; Violino)

2. Customizability

ISO 31000 is also highly customizable since it does not include advice, guidance, or detailed instructions on how to manage specific risks, but rather provides definitions, principles, and recommendations on processes and the framework itself. (Marsden, 3) This opens up options for RG Enterprises to take advantage of its small size and spread out the responsibilities among its team and maximize its resources. Involving the whole team also encourages ownership of the risk management process and creates empowered employees, increasing their confidence and the likelihood of identifying, acting on, and reporting future identified risks. (Gartner, 6)

3. Risk Management Process

The ISO 31000 Risk Management Process has five easy steps and two branching practices to follow for each step. (Marsden, 28) The steps and practices are shown in the diagram below:



source: (Marsden, 30)

These five steps are easy to understand and follow, especially with the encouragement to communicate and consult with all the stakeholders. This will help create a sense of unity, purpose, and collaboration. It will likely result in buy-in from all of the involved parties, from employees to managers and even the ownership of RG Enterprises. The Monitoring and Review practice will ensure that future risks are dealt with more efficiently and quickly. ISO 31000 differs from the NIST Risk Management Framework because, in addition to easy-to-follow steps (which NIST RMF shares with ISO 31000), ISO 31000 includes the extremely helpful branching practices that would be a great added benefit to RG Enterprises. (NIST) The easy steps and helpful branching practices make ISO 31000 the ideal framework for RG Enterprises.

4. Risk Management Framework

The Risk Management Framework suggestions in ISO 31000 include having risk architecture, strategy, and protocols. (Marsden, 31) The architecture aims to answer

who “owns” different risks, strategy aims to establish the objectives of the risk management activities in the organization, and protocols are how the strategy is implemented. (Marsden, 31) These practical suggestions help to establish a strong and flexible risk management framework that is easily understood and comprehensive, taking care to establish protocols explained by a strategy within an architecture that includes all members of the organization. This approach will help strengthen RG Enterprise’s unity and competence in managing risk as well as give it a strong framework from which to determine how to deal with future new risks.

5. Principles

In the ISO 31000 Risk Management Framework, the Principles guide the creation of the Framework, which in turn defines the Process. (Marsden, 34-35) These principles are determined by the organization, which gives RG Enterprises the control to customize its principles to reflect its values, business objectives, and resources. Being able to establish its own principles to guide the framework and determine the processes for risk management will greatly aid RG Enterprises to establish a strong risk management framework that will set it up for responsible and effective risk management.

RG Enterprises needs a robust Risk Management Framework so it can deal with the myriad of risks that it faces. Though there are various options to select, many frameworks are too complex, would take too long, or are not designed for organizations like RG Enterprises. With its generic approach, customizability, and its risk management process, framework, and principles, the ISO 31000 Risk Management Framework is an ideal Risk Management Framework for RG Enterprises.

Bibliography

Gartner. “Legal and Compliance Risk Management Framework.” Gartner,

<https://emt.gartnerweb.com/ngw/globalassets/en/legal-compliance/documents/insights/the-new-risk-landscape.pdf>

Marsden, Eric. The ISO 31 000 Standard on Risk Management.

<https://risk-engineering.org/static/PDF/slides-ISO31000-risk-management.pdf>.

NIST. “NIST Risk Management Framework.” NIST, 30 Nov. 2016,

<https://csrc.nist.gov/projects/risk-management/about-rmf>.

Upguard. “Effective Risk Management: The COSO ERM Framework | UpGuard.”

www.upguard.com, <https://www.upguard.com/blog/coso-erm-framework>.

Violino, Bob. “6 IT Risk Assessment Frameworks Compared.” CSO Online, 09 Aug. 2024, 4

<https://www.csoonline.com/article/525128/it-risk-assessment-frameworks-real-world-experience.html>.